

HỆ THỐNG QUẢN LÝ ĐẶT LỚP HỌC

CLASS BOOKING MANAGEMENT SYSTEM

TÀI LIỆU ĐẶC TẢ YÊU CẦU PHẦN MỀM

Software Requirements Specification v2.0 — Luồng Chi Tiết • Mô Tả UI • Mã Lỗi

Phiên bản	2.0 — Hoàn chỉnh
Ngày cập nhật	Tháng 5, 2026
Nền tảng	REST API + PostgreSQL
Phạm vi tài liệu	Luồng • UI • Mã lỗi API & Logic

1. TỔNG QUAN HỆ THỐNG

1.1 Mục tiêu

Hệ thống Quản lý Đặt Lớp Học (Class Booking Management System) là ứng dụng web xây dựng trên REST API, tích hợp PostgreSQL. Hệ thống quản lý toàn bộ vòng đời yêu cầu đặt phòng học: tạo → xem xét → phê duyệt, với phân quyền rõ ràng theo vai trò.

1.2 Vai trò người dùng

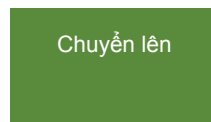
Vai trò	Role Code	Quyền thực hiện	Không được phép
Quản trị viên	ADMIN	Toàn quyền hệ thống, cấu hình, user, báo cáo	—
Người tạo	CREATOR	Tạo/sửa/hủy booking của mình, xem trạng thái	Xem booking người khác, phê duyệt
Người xem xét	REVIEWER	Xem xét, ghi nhận xét, chuyển tiếp / từ chối	Phê duyệt cuối, tạo/sửa booking
Người phê duyệt	APPROVER	Phê duyệt hoặc từ chối yêu cầu từ Reviewer	Tạo booking, xem xét lần đầu

1.3 Bảng trạng thái Booking

Mã trạng thái	Badge UI	Mô tả & Điều kiện chuyển trạng thái
DRAFT	 Xám	Creator đang soạn. Có thể sửa/xóa tự do. Chỉ Creator thấy.
PENDING_REVIEW	 Vàng	Creator đã submit. Chờ Reviewer nhận xử lý.
IN_REVIEW	 Xanh dương	Reviewer đang xem xét (đã claim việc).
PENDING_APPROVAL	 Cam	Reviewer chuyển lên Approver. Chờ phê duyệt cuối.
APPROVED	 Xanh lá	Approver phê duyệt. Phòng học bị block trong lịch.
REJECTED	 Đỏ	Bị từ chối ở Reviewer hoặc Approver. Không thể khôi phục.
CANCELLED	 Đen nhạt	Creator hủy chủ động (chỉ khi DRAFT hoặc PENDING_REVIEW).

1.4 Quy trình tổng quan

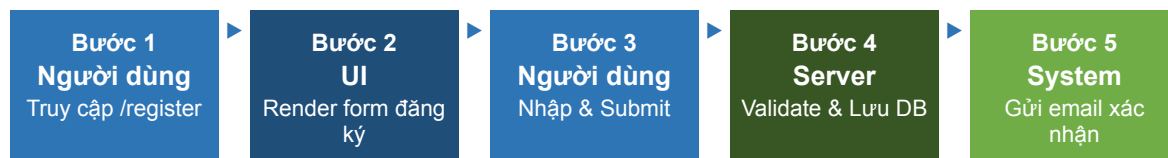




2. LƯỒNG XÁC THỰC NGƯỜI DÙNG (Authentication)

2.1 Đăng Ký Tài Khoản (User Registration)

2.1.1 Sơ đồ luồng



2.1.2 Mô tả màn hình /register

Layout & thành phần UI:

- Header: Logo hệ thống + tiêu đề 'Tạo tài khoản mới'
- Card trắng bo góc giữa màn hình, width max 480px
- Field [Họ và tên *] — placeholder: 'Nguyễn Văn A'
- Field [Email *] — placeholder: 'example@company.com'
- Field [Tên đăng nhập *] — placeholder: '6-50 ký tự, không dấu'
- Field [Mật khẩu *] — icon toggle show/hide — thanh strength: Yếu ● /Trung bình ●● /Mạnh ●●●
- Field [Xác nhận mật khẩu *] — hiển thị ☒ xanh khi khớp, ☐ đỏ khi không khớp
- Field [Số điện thoại] — optional — mask: 0XX-XXX-XXXX
- Dropdown [Phòng ban] — optional
- Checkbox [Tôi đồng ý Điều khoản & Chính sách] — bắt buộc tick trước khi submit
- Button [Đăng ký] primary — disabled khi form chưa hợp lệ — loading spinner khi đang gửi
- Link 'Đã có tài khoản? Đăng nhập ngay' → /login

2.1.3 Validation client-side (trước khi gửi API)

Trường	Điều kiện	Thông báo lỗi hiển thị inline
Họ và tên	2–100 ký tự, không chứa số & ký tự đặc biệt	'Họ tên phải từ 2–100 ký tự, chỉ chữ cái'
Email	Đúng định dạng RFC 5321	'Địa chỉ email không đúng định dạng'
Tên đăng nhập	6–50 ký tự, regex: <code>^[a-zA-Z0-9_]+\$</code>	'Chỉ chữ cái, số và dấu gạch dưới (6-50 ký tự)'
Mật khẩu	≥8 ký tự, có ít nhất 1 HOA, 1 thường, 1 số	'Mật khẩu cần ít nhất 8 ký tự, gồm chữ hoa, thường và số'
Xác nhận MK	Khớp 100% với password	'Mật khẩu xác nhận chưa khớp'
SĐT (optional)	10 chữ số, bắt đầu bằng 0	'Số điện thoại phải gồm 10 chữ số'
Checkbox ToS	Phải được tick	'Vui lòng đồng ý với điều khoản sử dụng'

2.1.4 Xử lý server-side

- Nhận POST `/api/v1/auth/register`

2. Validate lại toàn bộ (server không tin client)
3. Kiểm tra email unique trong DB → ERR_EMAIL_EXISTS nếu trùng
4. Kiểm tra username unique → ERR_USERNAME_EXISTS nếu trùng
5. Hash password: bcrypt(password, 12)
6. INSERT users(full_name, email, username, password_hash, role='CREATOR', status='INACTIVE')
7. Tạo email_verification_token = UUIDv4, lưu vào bảng email_verifications với TTL 24 giờ
8. Gửi email: link /verify-email?token=<uuid> (TTL 24h)
9. Ghi audit_log: action='USER_REGISTER', actor=email
10. Response 201: { message: 'Đăng ký thành công. Vui lòng kiểm tra email.' }

2.1.5 Màn hình sau đăng ký — /register-success

- Thông báo thành công: icon , tiêu đề 'Đăng ký thành công!'
- Nội dung: 'Chúng tôi đã gửi email xác nhận đến <email>. Nhấn vào link trong email để kích hoạt tài khoản.'
- Nút [Gửi lại email] — disabled 60 giây sau khi gửi, có countdown
- Link 'Quay lại trang đăng nhập'

Mã lỗi API — Đăng ký

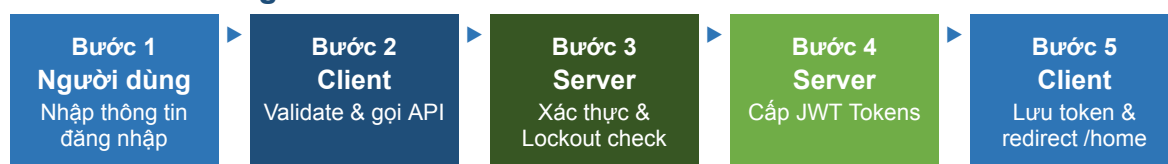
- 201 | SUCCESS | Đăng ký thành công, email xác nhận đã gửi
- 400 | ERR_VALIDATION | Dữ liệu đầu vào không hợp lệ hoặc thiếu trường bắt buộc
- 409 | ERR_EMAIL_EXISTS | Email đã được sử dụng bởi tài khoản khác
- 409 | ERR_USERNAME_EXISTS | Tên đăng nhập đã tồn tại trong hệ thống
- 422 | ERR_PASSWORD_WEAK | Mật khẩu không đủ tiêu chí độ phức tạp
- 422 | ERR_PASSWORD_MISMATCH | Mật khẩu xác nhận không khớp
- 429 | ERR_RATE_LIMIT | Quá 5 request đăng ký từ cùng IP trong 1 phút
- 500 | ERR_INTERNAL | Lỗi máy chủ nội bộ
- 503 | ERR_EMAIL_SERVICE_DOWN | Không gửi được email xác nhận (email server lỗi)

Mã lỗi Logic — Đăng ký

- LOGIC-REG-001 | Email đã xác nhận nhưng tài khoản vẫn INACTIVE → Admin cần kích hoạt thủ công
- LOGIC-REG-002 | Link xác nhận email đã hết hạn (>24h) → Yêu cầu gửi lại, token cũ bị vô hiệu
- LOGIC-REG-003 | Người dùng đăng ký lại email đã bị soft-delete → Thông báo 'Email đã tồn tại' (không tiết lộ xóa)

2.2 Đăng Nhập (Login)

2.2.1 Sơ đồ luồng



2.2.2 Mô tả màn hình /login

- Header: Logo + tên hệ thống
- Card trung tâm, width max 420px
- Field [Tên đăng nhập hoặc Email *] — autofocus khi vào trang
- Field [Mật khẩu *] — icon  toggle hiện/ẩn mật khẩu
- Checkbox [Ghi nhớ đăng nhập] — kéo dài Refresh Token 7 ngày → 30 ngày
- Button [Đăng nhập] — loading spinner khi gọi API
- Hiển thị số lần thử còn lại khi sai từ lần 3: 'Bạn còn X lần thử trước khi bị khóa'
- Banner  khi bị khóa: 'Tài khoản tạm khóa đến HH:MM DD/MM/YYYY'
- Link [Quên mật khẩu?] → /forgot-password
- Link [Đăng ký tài khoản mới] → /register

2.2.3 Xử lý server-side chi tiết

11. Nhận POST /api/v1/auth/login { username_or_email, password, remember_me }
12. Tìm user theo email hoặc username trong DB
13. Không tìm thấy → ERR_INVALID_CREDENTIALS (không tiết lộ field nào sai)
14. Kiểm tra locked_until: nếu locked_until > NOW() → ERR_ACCOUNT_LOCKED { unlock_at }
15. Kiểm tra status: INACTIVE → ERR_ACCOUNT_INACTIVE; deleted_at NOT NULL → ERR_INVALID_CREDENTIALS
16. bcrypt.compare(password, hash) — nếu SAI:
 - Tăng failed_login_count += 1
 - Nếu failed_login_count >= 5: SET locked_until = NOW()+15min, failed_login_count = 0
 - Trả ERR_INVALID_CREDENTIALS + { remaining_attempts: 5 - failed_login_count }
17. Mật khẩu ĐÚNG: SET failed_login_count=0, locked_until=NULL
18. Tạo Access Token (JWT RS256): payload { user_id, role, email, jti }, TTL=15min
19. Tạo Refresh Token: UUIDv4, hash SHA-256 lưu DB, TTL=7d (hoặc 30d nếu remember_me=true)
20. INSERT login_history(user_id, ip, user_agent, status='SUCCESS', timestamp)
21. Response 200: { access_token, refresh_token, expires_in:900, user:{id,full_name,role,email} }

2.2.4 Luồng Refresh Token (tự động gia hạn)

22. Access Token sắp hết hạn (< 2 phút) → Client gọi POST /api/v1/auth/refresh
23. Server hash Refresh Token → tìm trong DB, kiểm tra: chưa hết hạn, revoked=false, user ACTIVE
24. Cấp Access Token mới (TTL 15 phút), tùy chọn rotate Refresh Token
25. Nếu Refresh Token hết hạn → buộc đăng xuất, redirect /login?reason=session_expired

Mã lỗi API — Đăng nhập

- 200 | SUCCESS | Đăng nhập thành công, trả về tokens
- 400 | ERR_VALIDATION | Thiếu username_or_email hoặc password
- 401 | ERR_INVALID_CREDENTIALS | Sai thông tin (không tiết lộ field cụ thể nào sai)
- 403 | ERR_ACCOUNT_INACTIVE | Tài khoản chưa được Admin kích hoạt
- 403 | ERR_EMAIL_NOT_VERIFIED | Chưa xác nhận email (nếu bật tính năng)
- 423 | ERR_ACCOUNT_LOCKED | Tài khoản bị khóa tạm thời (kèm unlock_at timestamp)
- 429 | ERR_RATE_LIMIT | Quá 20 request/phút từ IP này
- 500 | ERR_INTERNAL | Lỗi máy chủ nội bộ

Mã lỗi Logic — Đăng nhập

- LOGIC-LOGIN-001 | Cùng 1 IP thử nhiều tài khoản khác nhau → Rate limit IP-level (block 30 phút)
- LOGIC-LOGIN-002 | Access Token hết hạn → Client gọi /refresh tự động; nếu lỗi → force logout
- LOGIC-LOGIN-003 | Refresh Token bị dùng lần 2 (replay attack) → Revoke TOÀN BỘ session của user
- LOGIC-LOGIN-004 | Admin thay đổi role user khi đang đăng nhập → Token cũ vẫn hợp lệ đến khi hết TTL
- LOGIC-LOGIN-005 | User bị Admin lock trong khi đang dùng → Access Token hết hạn sau 15 phút sẽ không refresh được

2.3 Đăng Xuất (Logout)

2.3.1 Các loại đăng xuất

Loại đăng xuất	Endpoint	Tác động
Đăng xuất thiết bị hiện tại	POST /api/v1/auth/logout	Revoke Refresh Token hiện tại. Các thiết bị khác vẫn đăng nhập.
Đăng xuất tất cả thiết bị	POST /api/v1/auth/logout-all	Revoke toàn bộ Refresh Token của user trong DB.
Tự động — Token hết hạn	Client-side redirect	Xóa token khỏi bộ nhớ, redirect /login?reason=expired
Bị Admin khóa / vô hiệu	Server revoke ngay	Toàn bộ session bị invalidate ngay lập tức.

2.3.2 Xử lý server-side

26. Nhận POST /api/v1/auth/logout + Bearer Token trong header Authorization
27. Verify JWT → lấy user_id, jti
28. Hash Refresh Token từ body → tìm trong bảng refresh_tokens
29. Đánh dấu: SET revoked=true, revoked_at=NOW()
30. Ghi audit_log: action='USER_LOGOUT', actor=user_id
31. Response 200: { message: 'Đăng xuất thành công' }
32. Client: xóa access_token & refresh_token → redirect /login

⚠ Mã lỗi API — Đăng xuất

- 200 | SUCCESS | Đăng xuất thành công
- 401 | ERR_TOKEN_MISSING | Không có Bearer token trong Authorization header
- 401 | ERR_TOKEN_INVALID | Token không hợp lệ hoặc đã hết hạn
- 404 | ERR_TOKEN_NOT_FOUND | Refresh token không tồn tại trong DB

3. TRANG CHỦ — HOMEPAGE (/home)

3.1 Mô tả tổng quan màn hình

Trang chủ là màn hình chính sau khi đăng nhập. Nội dung được tùy biến theo vai trò người dùng. Gồm 3 vùng chính: Navigation Bar (trên cùng), Sidebar (bên trái), và Content Area (giữa/phải).

3.1.1 Navigation Bar (Header cố định)

- Logo hệ thống + tên hệ thống (góc trái)
- Menu điều hướng: Trang chủ | Đặt lớp | Lịch | Thông báo (badge số chưa đọc) | Hồ sơ
- Avatar người dùng + tên + dropdown: Hồ sơ cá nhân / Đổi mật khẩu / Đăng xuất
- Icon 🔔 Thông báo — badge đỏ hiển thị số chưa đọc, click mở panel thông báo

3.1.2 Sidebar (bên trái, responsive collapse trên mobile)

- ADMIN: Dashboard | Quản lý User | Quản lý Phòng học | Tất cả Booking | Cấu hình | Audit Log
- CREATOR: Booking của tôi | Tạo booking mới | Lịch phòng học
- REVIEWER: Chờ xem xét | Đang xem xét | Lịch sử xem xét
- APPROVER: Chờ phê duyệt | Lịch sử phê duyệt

3.1.3 Content Area — Dashboard thống kê

Vai trò	Thẻ thống kê (KPI Cards)	Nội dung danh sách
ADMIN	Tổng booking / Đang chờ / Đã phê duyệt / Từ chối	Tất cả booking hệ thống, biểu đồ theo tuần/tháng
CREATOR	Của tôi: DRAFT / Đang xử lý / Approved	Chỉ booking của bản thân, sắp xếp theo ngày tạo
REVIEWER	Chờ xem xét / Đang xem / Đã xử lý hôm nay	Booking cần xem xét, ưu tiên theo thời gian chờ
APPROVER	Chờ phê duyệt / Đã approve / Đã reject hôm nay	Booking cần phê duyệt từ Reviewer chuyển lên

3.1.4 Danh sách booking — cấu trúc từng dòng

- Badge trạng thái màu sắc (DRAFT/PENDING/APPROVED...)
- Tiêu đề booking + tên phòng học
- Người tạo + phòng ban (Reviewer/Approver/Admin thấy)
- Thời gian học: DD/MM/YYYY HH:mm – HH:mm
- Thời gian chờ (bao lâu chưa được xử lý) — màu cam nếu > 24h, đỏ nếu > 48h
- Nút hành động: [Xem chi tiết] | [Xem xét] (Reviewer) | [Phê duyệt] (Approver)

3.2 Tính năng lọc & tìm kiếm

Bộ lọc	Mô tả
Trạng thái	Multi-select: DRAFT / PENDING_REVIEW / IN_REVIEW / PENDING_APPROVAL / APPROVED / REJECTED / CANCELLED
Khoảng thời gian	Date range picker: Từ ngày – Đến ngày (lọc theo start_datetime của lớp học)
Phòng học	Dropdown chọn phòng (Admin/Reviewer/Approver)
Người tạo	Chỉ Admin, Reviewer, Approver mới có bộ lọc này
Tìm kiếm	Full-text search theo tiêu đề booking (debounce 300ms)
Sắp xếp	Ngày tạo mới nhất / Ngày học gần nhất / Thời gian chờ lâu nhất / Trạng thái
Phân trang	page (mặc định 1), limit (mặc định 20). Hiển thị: 'Trang X/Y — Tổng N kết quả'

⚠ Mã lỗi API — Homepage

- 200 | SUCCESS | Trả về danh sách booking và thống kê
- 401 | ERR_UNAUTHORIZED | Token hết hạn hoặc không hợp lệ → redirect /login
- 403 | ERR_FORBIDDEN | Cố gắng lọc theo người khác (Creator xem booking người khác)
- 500 | ERR_INTERNAL | Lỗi truy vấn DB

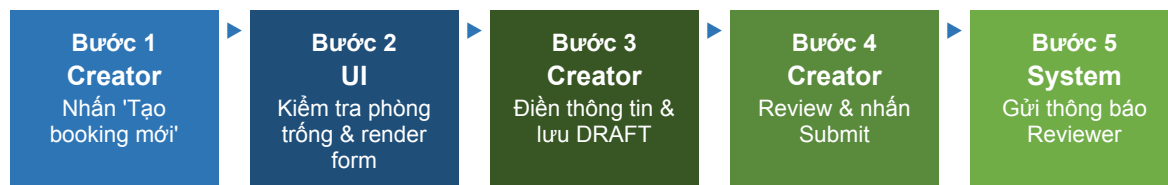
💡 Mã lỗi Logic — Homepage

- LOGIC-HOME-001 | Creator gọi API với filter creator_id khác → Server trả 403, ghi audit_log
- LOGIC-HOME-002 | Phòng học bị xóa nhưng booking vẫn tồn tại → Hiển thị '[Phòng đã xóa]' thay tên
- LOGIC-HOME-003 | Booking APPROVED nhưng phòng bị đặt trùng (lỗi dữ liệu) → Hiển thị cảnh báo ⚠ cho Admin

4. LUỒNG ĐẶT LỚP HỌC CHI TIẾT

4.1 Luồng Creator Tạo Yêu Cầu

4.1.1 Sơ đồ luồng tạo & submit booking



4.1.2 Màn hình tạo booking — /bookings/new

Bố cục màn hình:

- Breadcrumb: Trang chủ > Đặt lớp học > Tạo mới
- Title: 'Tạo yêu cầu đặt lớp học'
- Panel trái (2/3 màn hình): Form nhập liệu
- Panel phải (1/3 màn hình): Lịch mini hiển thị phòng đã đặt theo thời gian chọn

Các trường trong form:

Trường	Loại UI	Bắt buộc	Mô tả & Ràng buộc
Tiêu đề	Text input	✓	Tối đa 200 ký tự. Hiển thị bộ đếm ký tự.
Phòng học	Searchable dropdown	✓	Chỉ hiện phòng AVAILABLE. Khi chọn → panel phải cập nhật lịch.
Ngày học	Date picker	✓	Chỉ chọn ngày tương lai. Block ngày quá khứ và ngày phòng kín.
Giờ bắt đầu	Time picker	✓	Bước 30 phút. Phải cách hiện tại ít nhất 2 giờ.
Giờ kết thúc	Time picker	✓	Phải sau giờ bắt đầu. Tối đa 8 giờ/booking.
Mục đích	Textarea	✓	Tối đa 500 ký tự. Bắt buộc mô tả rõ mục đích.
Số người tham dự	Number input	✓	Không vượt sức chứa phòng. Hiển thị: 'Tối đa N người'.
Mô tả chi tiết	Rich textarea	—	Tùy chọn. Tối đa 2000 ký tự.
Thiết bị cần	Multi-checkbox	—	Máy chiếu / Điều hòa / Micro / Bảng trắng / Máy tính
File đính kèm	File upload	—	Tối đa 5 file, mỗi file ≤ 10MB. PDF/DOCX/PNG/JPG.

4.1.3 Nút hành động trên form

- Nút [Lưu nháp] — lưu ở trạng thái DRAFT, không gửi Reviewer

- Nút [Submit gửi xem xét] — chuyển DRAFT → PENDING_REVIEW, không thể sửa sau khi submit
- Nút [Hủy] — xác nhận dialog 'Bạn có chắc muốn hủy? Dữ liệu chưa lưu sẽ mất.'
- Auto-save DRAFT mỗi 60 giây (hiển thị 'Đã lưu tự động lúc HH:mm')

4.1.4 Xử lý server khi tạo booking

33. POST /api/v1/bookings — Server nhận và xử lý:
34. Validate: phòng tồn tại & status=AVAILABLE
35. Conflict check: SELECT * FROM bookings WHERE class_id=? AND status IN (PENDING_REVIEW,IN_REVIEW,PENDING_APPROVAL,APPROVED) AND (start BETWEEN ? AND ? OR end BETWEEN ? AND ?)
36. Kiểm tra thời gian hợp lệ: start > NOW()+2h, end > start, end-start ≤ 8h
37. Kiểm tra quota: số booking ACTIVE của Creator trong tuần < giới hạn cấu hình
38. INSERT bookings → trả 201 { booking_id, status:'DRAFT' }
39. Khi Creator Submit: PATCH /api/v1/bookings/:id/submit → status: DRAFT → PENDING_REVIEW
40. Gửi notification đến tất cả Reviewer trong hệ thống
41. Ghi booking_status_history: { from:'DRAFT', to:'PENDING_REVIEW', changed_by: creator_id }

⚠ Mã lỗi API — Tạo Booking

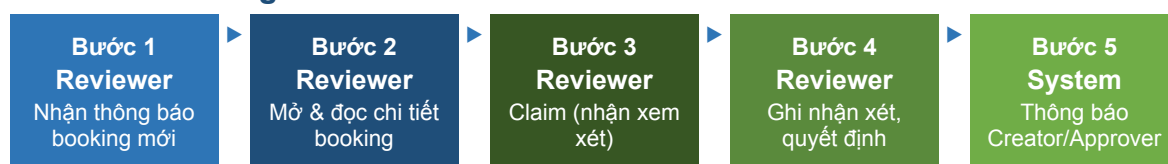
- | | |
|--------------------------------|--|
| • 201 SUCCESS | Tạo booking thành công (DRAFT) |
| • 200 SUCCESS_SUBMIT | Submit thành công → PENDING_REVIEW |
| • 400 ERR_VALIDATION | Dữ liệu thiếu hoặc sai định dạng |
| • 403 ERR_FORBIDDEN | Không phải CREATOR hoặc không sở hữu booking |
| • 404 ERR_CLASS_NOT_FOUND | Phòng học không tồn tại |
| • 409 ERR_CLASS_CONFLICT | Phòng đã được đặt trong khoảng thời gian này |
| • 422 ERR_TIME_TOO_SOON | Thời gian bắt đầu phải cách hiện tại ít nhất 2 giờ |
| • 422 ERR_TIME_TOO_FAR | Không được đặt trước quá 30 ngày |
| • 422 ERR_DURATION_EXCEEDED | Thời lượng tối đa 8 giờ/booking |
| • 422 ERR_ATTENDEES_EXCEEDED | Số người vượt sức chứa phòng |
| • 422 ERR_QUOTA_EXCEEDED | Vượt giới hạn số booking cho phép trong tuần |
| • 422 ERR_CANNOT_SUBMIT | Chỉ booking ở trạng thái DRAFT mới được submit |
| • 415 ERR_FILE_TYPE_INVALID | Định dạng file đính kèm không được hỗ trợ |
| • 413 ERR_FILE_TOO_LARGE | File đính kèm vượt quá 10MB |

💡 Mã lỗi Logic — Tạo Booking

- LOGIC-BOOK-001 | Phòng AVAILABLE nhưng có booking APPROVED trùng giờ → ERR_CLASS_CONFLICT (lỗi dữ liệu cần Admin xử lý)
- LOGIC-BOOK-002 | Creator submit booking DRAFT đã quá 30 ngày tạo → Cảnh báo 'Thông tin có thể cũ, vui lòng cập nhật'
- LOGIC-BOOK-003 | Creator tạo 2 booking cùng phòng liên tiếp < 30 giây → Cảnh báo duplicate, yêu cầu xác nhận
- LOGIC-BOOK-004 | Phòng học chuyển sang MAINTENANCE sau khi Creator đã lưu DRAFT → Cảnh báo khi Creator mở lại

4.2 Luồng Reviewer Xem Xét

4.2.1 Sơ đồ luồng



4.2.2 Màn hình danh sách chờ xem xét — /reviewer/queue

- Tiêu đề: 'Yêu cầu chờ xem xét' + badge số lượng
- Bảng danh sách: Tiêu đề | Người tạo | Phòng | Thời gian học | Thời gian chờ | Hành động
- Cột 'Thời gian chờ': màu xanh (<24h), cam (24-48h), đỏ (>48h)
- Nút [Xem & Xem xét] → mở trang chi tiết booking
- Filter: Chờ xem xét / Đang xem xét / Đã xử lý — Sắp xếp theo: Thời gian chờ lâu nhất

4.2.3 Màn hình chi tiết booking cho Reviewer — /reviewer/bookings/:id

- Phần thông tin booking: đầy đủ thông tin Creator nhập (readonly)
- Phần lịch phòng: mini calendar hiển thị các slot đã đặt của phòng đó
- Phần thông tin Creator: tên, phòng ban, lịch sử booking gần đây
- Panel nhận xét: textarea 'Nhận xét của Reviewer' (bắt buộc trước khi chuyển tiếp hoặc từ chối)
- Nút [Nhận xem xét] → claim booking, chuyển PENDING_REVIEW → IN_REVIEW
- Nút [Chuyển lên Approver] — chỉ active sau khi đã nhập nhận xét — IN_REVIEW → PENDING_APPROVAL
- Nút [Từ chối] — mở dialog xác nhận + bắt buộc nhập lý do từ chối
- Tab lịch sử: xem toàn bộ các thay đổi trạng thái của booking này

4.2.4 Xử lý server

42. PATCH /api/v1/bookings/:id/claim → PENDING_REVIEW → IN_REVIEW (reviewer_id = current_user)
43. Chỉ 1 Reviewer được claim 1 booking (tránh 2 người cùng xem xét)
44. POST /api/v1/bookings/:id/comments { content, is_internal } → lưu booking_comments
45. PATCH /api/v1/bookings/:id/forward → IN_REVIEW → PENDING_APPROVAL — Bắt buộc có comment
46. PATCH /api/v1/bookings/:id/reject { reason } → status=REJECTED — Ghi lý do vào status_history
47. Gửi notification: Creator nhận kết quả — Approver nhận yêu cầu mới (nếu forward)
48. Ghi booking_status_history cho mỗi thay đổi

⚠ Mã lỗi API — Reviewer

- 200 | SUCCESS | Thao tác thành công
- 403 | ERR_NOT_REVIEWER | Người dùng không có role REVIEWER
- 403 | ERR_ALREADY_CLAIMED | Booking đã được Reviewer khác claim
- 404 | ERR_BOOKING_NOT_FOUND | Booking không tồn tại
- 409 | ERR_WRONG_STATUS | Booking không ở trạng thái phù hợp để thực hiện thao tác
- 422 | ERR_COMMENT_REQUIRED | Phải có nhận xét trước khi chuyển tiếp hoặc từ chối

• 422 | ERR_REASON_REQUIRED | Phải nhập lý do từ chối



Mã lỗi Logic — Reviewer

- LOGIC-REV-001 | Reviewer cố xem xét booking không thuộc phạm vi mình → 403 + audit_log
- LOGIC-REV-002 | Reviewer claim rồi không xử lý > 48h → Hệ thống tự unclaim, gửi cảnh báo Admin
- LOGIC-REV-003 | Creator hủy booking khi Reviewer đang IN_REVIEW → Thông báo cho Reviewer, booking chuyển CANCELLED
- LOGIC-REV-004 | Reviewer từ chối booking đã APPROVED (lỗi trạng thái) → Server trả 409 ERR_WRONG_STATUS

4.3 Luồng Approver Phê Duyệt

4.3.1 Sơ đồ luồng



4.3.2 Màn hình Approver — /approver/queue

- Tiêu đề 'Yêu cầu chờ phê duyệt' + badge số lượng
- Hiển thị: Tiêu đề | Người tạo | Phòng | Thời gian học | Reviewer đã xem xét | Ngày chờ | Hành động
- Ưu tiên hiển thị booking chờ lâu nhất lên đầu
- Filter theo phòng học, khoảng thời gian, người tạo

4.3.3 Màn hình chi tiết — /approver/bookings/:id

- Đầy đủ thông tin booking (readonly)
- Nhận xét của Reviewer: hiển thị nổi bật trong panel riêng
- Lịch phòng: slot đặt phòng có thể bị ảnh hưởng
- Lịch sử toàn bộ trạng thái và comment của booking
- Panel quyết định: Textarea 'Nhận xét phê duyệt' (bắt buộc khi từ chối, tùy chọn khi approve)
- Nút [✓ Phê duyệt] xanh lá — confirm dialog 'Xác nhận phê duyệt booking này?'
- Nút [✗ Từ chối] đỏ — dialog bắt buộc nhập lý do từ chối

4.3.4 Xử lý server khi phê duyệt

49. PATCH /api/v1/bookings/:id/approve → status=APPROVED
50. INSERT calendar_blocks(class_id, start_datetime, end_datetime, booking_id) để block lịch phòng
51. Gửi email xác nhận đặt phòng cho Creator (kèm thông tin đầy đủ)
52. Gửi in-app notification cho Creator
53. Ghi booking_status_history { from:'PENDING_APPROVAL', to:'APPROVED', changed_by: approver_id }
54. Ghi audit_log: action='BOOKING_APPROVED'

4.3.5 Xử lý server khi từ chối

55. PATCH /api/v1/bookings/:id/reject { reason } → status=REJECTED
56. Gửi email thông báo từ chối kèm lý do cho Creator
57. Không giải phóng phòng (không có gì block)
58. Creator có thể xem lý do từ chối trong trang chi tiết booking

⚠ Mã lỗi API — Approver

- 200 | SUCCESS | Phê duyệt hoặc từ chối thành công
- 403 | ERR_NOT_APPROVER | Người dùng không có role APPROVER
- 404 | ERR_BOOKING_NOT_FOUND | Booking không tồn tại

- 409 | ERR_WRONG_STATUS | Booking phải ở PENDING_APPROVAL mới được phê duyệt/từ chối
- 409 | ERR_CLASS_CONFLICT_ON_APPROVE | Phòng học bị đặt trùng tại thời điểm approve (race condition)
- 422 | ERR_REASON_REQUIRED | Bắt buộc nhập lý do khi từ chối



Mã lỗi Logic — Approver

- LOGIC-APP-001 | Race condition: 2 Approver phê duyệt cùng 1 booking → Chỉ 1 thành công, người sau nhận 409
- LOGIC-APP-002 | Phòng học APPROVED có lịch conflict với booking khác cũng APPROVED → Admin nhận alert ngay
- LOGIC-APP-003 | Approver phê duyệt nhưng email service lỗi → Booking vẫn APPROVED, email ghi vào queue retry
- LOGIC-APP-004 | Creator xóa tài khoản sau khi booking đã APPROVED → Booking vẫn giữ nguyên, hiển thị '[Tài khoản đã xóa]'

5. TRANG QUẢN TRỊ HỆ THỐNG (Admin)

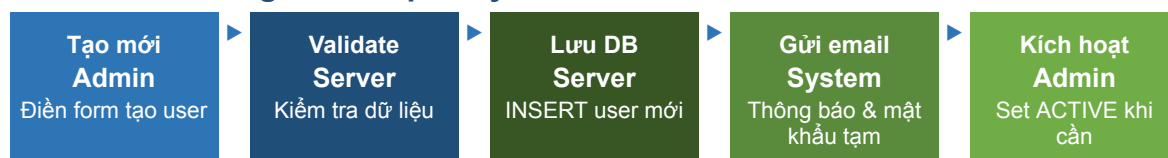
⚠ **Chỉ tài khoản có vai trò ADMIN mới được truy cập các trang và API trong mục này.**

5.1 Luồng Quản Lý Người Dùng

5.1.1 Màn hình danh sách user — /admin/users

- Tiêu đề: 'Quản lý người dùng' + Nút [+ Tạo tài khoản mới]
- Bảng: Avatar | Họ tên | Email | Tên đăng nhập | Vai trò | Trạng thái | Ngày tạo | Hành động
- Badge vai trò: ADMIN ● / CREATOR ● / REVIEWER ● / APPROVER ●
- Badge trạng thái: ACTIVE ✔ / INACTIVE ■ / LOCKED ●
- Hành động mỗi dòng: [Chi tiết] [Sửa] [Đổi role] [Kích hoạt/Vô hiệu] [Xóa]
- Thanh tìm kiếm: tìm theo tên, email, username
- Bộ lọc: Vai trò (multi-select) | Trạng thái | Phòng ban
- Phân trang 20 user/trang

5.1.2 Sơ đồ luồng Admin quản lý user



5.1.3 Màn hình tạo/sửa user — /admin/users/new

- Field: Họ và tên (*) | Email (*) | Tên đăng nhập (*) | Vai trò (*) dropdown
- Field: Số điện thoại | Phòng ban | Ghi chú nội bộ
- Checkbox: Gửi email thông báo cho người dùng khi tạo
- Khi Admin tạo: hệ thống sinh mật khẩu tạm thời, gửi qua email, user phải đổi lần đầu đăng nhập
- Trạng thái mặc định khi Admin tạo: ACTIVE (khác với tự đăng ký là INACTIVE)

5.1.4 Chi tiết API & Xử lý

Method	Endpoint	Mô tả xử lý
GET	/api/v1/admin/users	Danh sách users: phân trang, lọc theo role/status/search
GET	/api/v1/admin/users/:id	Chi tiết user: thông tin + lịch sử booking + login_history
POST	/api/v1/admin/users	Tạo user: validate, hash password tạm, gửi email
PUT	/api/v1/admin/users/:id	Cập nhật thông tin (full_name, phone, department, role)
PATCH	/api/v1/admin/users/:id/status	Kích hoạt / Vô hiệu hóa. Ghi audit_log.
PATCH	/api/v1/admin/users/:id/role	Đổi role. Không thể hạ role Admin cuối cùng.

DELETE	/api/v1/admin/users/:id	Soft delete: set deleted_at=NOW(). Revoke tất cả token.
POST	/api/v1/admin/users/:id/unlock	Mở khóa tài khoản bị locked. Reset failed_login_count=0.

Mã lỗi API — Admin User Management

- 200/201 | SUCCESS | Thao tác thành công
- 400 | ERR_VALIDATION | Dữ liệu không hợp lệ
- 403 | ERR_NOT_ADMIN | Chỉ Admin mới được thực hiện
- 404 | ERR_USER_NOT_FOUND | Người dùng không tồn tại
- 409 | ERR_EMAIL_EXISTS | Email đã tồn tại khi tạo mới
- 409 | ERR_USERNAME_EXISTS | Tên đăng nhập đã tồn tại
- 422 | ERR_CANNOT_DELETE_LAST_ADMIN | Không thể xóa Admin cuối cùng
- 422 | ERR_CANNOT_DEMOTE_LAST_ADMIN | Không thể hạ quyền Admin cuối cùng
- 422 | ERR_SELF_DEACTIVATE | Admin không thể tự vô hiệu hóa tài khoản của chính mình

Mã lỗi Logic — Admin User Management

- LOGIC-ADM-USR-001 | Admin vô hiệu tài khoản đang đăng nhập → Token hết hạn sau 15 phút không refresh được
- LOGIC-ADM-USR-002 | Admin xóa user đang có booking PENDING/IN_REVIEW → Cảnh báo: 'User có N booking đang xử lý'
- LOGIC-ADM-USR-003 | Admin đổi role REVIEWER → CREATOR khi Reviewer đang IN_REVIEW → Cảnh báo, yêu cầu reassign
- LOGIC-ADM-USR-004 | Import user hàng loạt từ CSV: lỗi 1 dòng không làm rollback toàn bộ batch

5.2 Luồng Quản Lý Phòng Học

5.2.1 Màn hình /admin/classes

- Danh sách phòng dạng lưới (grid) hoặc bảng — toggle view
- Mỗi phòng hiển thị: Tên phòng | Vị trí | Sức chứa | Thiết bị | Trạng thái | Booking hôm nay
- Badge trạng thái: AVAILABLE  / MAINTENANCE  / CLOSED 
- Nút [+ Thêm phòng] | [Xem lịch] | [Sửa] | [Đổi trạng thái] | [Xóa]
- Tab 'Lịch phòng': calendar view toàn bộ booking của phòng đó

5.2.2 Form tạo/sửa phòng — /admin/classes/new

- Tên phòng (*): unique trong hệ thống
- Mô tả: textarea tùy chọn
- Vị trí: Tòa nhà | Tầng | Phòng số
- Sức chứa (*): số người tối đa (>0)
- Thiết bị: multi-checkbox (Máy chiếu / Điều hòa / Micro / Bảng trắng / Máy tính / Wifi riêng)
- Ảnh phòng: upload tối đa 5 ảnh, mỗi ảnh ≤ 5MB, JPG/PNG
- Giờ hoạt động: từ HH:mm đến HH:mm (không cho đặt ngoài khung giờ này)

Mã lỗi API — Admin Class Management

- 201 | SUCCESS | Tạo phòng thành công
- 400 | ERR_VALIDATION | Dữ liệu không hợp lệ
- 409 | ERR_CLASS_NAME_EXISTS | Tên phòng đã tồn tại
- 422 | ERR_CANNOT_DELETE_CLASS | Phòng có booking đang hoạt động (APPROVED tương lai), không thể xóa
- 422 | ERR_CANNOT_CLOSE_CLASS | Phòng có booking APPROVED trong tương lai, không thể đóng ngay

Mã lỗi Logic — Admin Class Management

- LOGIC-ADM-CLS-001 | Admin đổi AVAILABLE→MAINTENANCE: cảnh báo danh sách booking bị ảnh hưởng, cho chọn notify Creator
- LOGIC-ADM-CLS-002 | Admin giảm sức chứa phòng xuống dưới attendees_count của booking APPROVED → Alert, không tự cancel booking
- LOGIC-ADM-CLS-003 | Phòng bị xóa mềm vẫn hiển thị '[Phòng đã xóa]' trong booking history

5.3 Luồng Admin Giám Sát Toàn Bộ Booking

5.3.1 Màn hình /admin/bookings

- Xem tất cả booking không giới hạn vai trò người tạo
- Bộ lọc đầy đủ: trạng thái / phòng / người tạo / Reviewer / Approver / khoảng thời gian
- Nút [Export Excel] — xuất file theo bộ lọc hiện tại
- Cột bổ sung so với user thường: Reviewer | Approver | Thời gian qua từng bước
- Admin có thể Cancel bất kỳ booking nào (trừ APPROVED đã qua ngày học)
- Admin có thể Reassign Reviewer cho booking đang IN_REVIEW

5.3.2 Dashboard Admin — /admin/dashboard

- KPI Cards: Tổng booking tháng này | Đang xử lý | Tỷ lệ phê duyệt | Thời gian xử lý TB
- Biểu đồ đường: Booking mới theo ngày (7 ngày / 30 ngày)
- Biểu đồ tròn: Phân bố trạng thái booking
- Bảng: Top 5 phòng được đặt nhiều nhất
- Bảng: Booking đang chờ > 48 giờ (cảnh báo SLA)

Mã lỗi API — Admin Booking Oversight

- 200 | SUCCESS | Trả về danh sách/chi tiết
- 403 | ERR_NOT_ADMIN | Chỉ Admin mới được truy cập
- 422 | ERR_CANNOT_CANCEL | Không thể hủy booking APPROVED đã qua ngày học
- 500 | ERR_EXPORT_FAILED | Lỗi khi tạo file Excel export

5.4 Cấu Hình Hệ Thống — /admin/config

Tham số cấu hình	Mặc định	Mô tả
booking_min_hours_advance	2 giờ	Thời gian tối thiểu phải đặt trước giờ học
booking_max_days_advance	30 ngày	Không được đặt xa hơn N ngày trong tương lai
booking_max_duration_hours	8 giờ	Thời lượng tối đa mỗi booking
weekly_booking_quota	5 booking	Số booking mỗi Creator được tạo trong 1 tuần
auto_unclaim_hours	48 giờ	Tự unclaim Reviewer nếu không xử lý sau N giờ
allow_self_registration	true	Cho phép người dùng tự đăng ký hay chỉ Admin tạo
email_notifications_enabled	true	Bật/tắt toàn bộ thông báo email hệ thống
max_file_size_mb	10 MB	Kích thước tối đa mỗi file đính kèm

5.5 Audit Log — /admin/audit-logs

- Ghi lại: thao tác / actor / đối tượng bị tác động / IP / timestamp / trước-sau thay đổi
- Không thể sửa hoặc xóa audit log
- Lọc theo: Loại thao tác | Actor | Khoảng thời gian | Đối tượng (user_id / booking_id)
- Export audit log ra CSV/Excel

Loại Action	Khi nào ghi
USER_REGISTER	Người dùng đăng ký tài khoản mới
USER_LOGIN / USER_LOGOUT	Mỗi lần đăng nhập thành công / đăng xuất
USER_LOGIN_FAILED	Đăng nhập thất bại (ghi kèm IP)
USER_ROLE_CHANGED	Admin thay đổi role người dùng
USER_STATUS_CHANGED	Kích hoạt / Vô hiệu hóa tài khoản
BOOKING_CREATED	Tạo booking mới
BOOKING_STATUS_CHANGED	Mỗi lần trạng thái booking thay đổi
BOOKING_CANCELLED	Hủy booking
CLASS_CREATED / UPDATED / DELETED	Thao tác CRUD phòng học
CONFIG_CHANGED	Admin thay đổi cấu hình hệ thống

6. THIẾT KẾ CƠ SỞ DỮ LIỆU POSTGRESQL

6.1 Danh sách bảng

Tên bảng	Kiểu dữ liệu chính	Mô tả
users	UUID PK	Tài khoản người dùng, vai trò, trạng thái
classes	UUID PK	Phòng học / lớp học
bookings	UUID PK	Yêu cầu đặt lớp học
booking_status_history	UUID PK	Lịch sử thay đổi trạng thái booking
booking_comments	UUID PK	Nhận xét trong quá trình xét duyệt
booking_attachments	UUID PK	File đính kèm của booking
calendar_blocks	UUID PK	Block lịch phòng khi booking APPROVED
email_verifications	UUID PK	Token xác nhận email đăng ký
refresh_tokens	UUID PK	Refresh Token người dùng (hashed)
login_history	UUID PK	Lịch sử đăng nhập: IP, user agent, status
notifications	UUID PK	Thông báo in-app cho người dùng
audit_logs	UUID PK	Nhật ký toàn bộ thao tác hệ thống
system_configs	KEY-VALUE	Cấu hình hệ thống do Admin quản lý

6.2 Chi tiết bảng users

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
id	UUID	PK	gen_random_uuid()
full_name	VARCHAR(100)	NOT NULL	Họ và tên đầy đủ
username	VARCHAR(50)	UNIQUE NOT NULL	Tên đăng nhập
email	VARCHAR(255)	UNIQUE NOT NULL	Địa chỉ email
password_hash	VARCHAR(255)	NOT NULL	bcrypt hash mật khẩu
role	user_role ENUM	NOT NULL	ADMIN CREATOR REVIEWER APPROVER
status	user_status ENUM	DEFAULT 'INACTIVE'	ACTIVE INACTIVE LOCKED

email_verified	BOOLEAN	DEFAULT false	Đã xác nhận email chưa
phone_number	VARCHAR(15)	NULLABLE	Số điện thoại
department	VARCHAR(100)	NULLABLE	Phòng ban / Bộ phận
failed_login_count	INTEGER	DEFAULT 0	Đếm số lần đăng nhập sai liên tiếp
locked_until	TIMESTAMP Z	NULLABLE	Thời gian mở khóa tài khoản
must_change_password	BOOLEAN	DEFAULT false	Bắt buộc đổi MK lần đầu (Admin tạo)
created_at	TIMESTAMP Z	DEFAULT NOW()	Thời gian tạo tài khoản
updated_at	TIMESTAMP Z	DEFAULT NOW()	Tự cập nhật qua trigger
deleted_at	TIMESTAMP Z	NULLABLE	Soft delete timestamp

6.3 Chi tiết bảng bookings

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
id	UUID	PK	Primary Key
title	VARCHAR(200)	NOT NULL	Tiêu đề yêu cầu
class_id	UUID	FK → classes	Phòng học được đặt
creator_id	UUID	FK → users	Người tạo yêu cầu
reviewer_id	UUID	FK → users NULLABLE	Reviewer được gán
approver_id	UUID	FK → users NULLABLE	Approver xử lý
start_datetime	TIMESTAMP Z	NOT NULL	Thời gian bắt đầu lớp học
end_datetime	TIMESTAMP Z	NOT NULL, > start	Thời gian kết thúc lớp học
status	booking_status ENUM	DEFAULT 'DRAFT'	Trạng thái hiện tại
purpose	TEXT	NOT NULL	Mục đích sử dụng phòng
attendees_count	INTEGER	NOT NULL, > 0	Số người tham dự

description	TEXT	NULLABLE	Mô tả chi tiết
equipment_needed	JSONB	NULLABLE	['projector','ac','mic'] v.v.
rejection_reason	TEXT	NULLABLE	Lý do từ chối (khi REJECTED)
created_at	TIMESTAMP Z	DEFAULT NOW()	Thời gian tạo
updated_at	TIMESTAMP Z	DEFAULT NOW()	Tự cập nhật qua trigger

6.4 Indexes quan trọng

Index	Mục đích
idx_bookings_creator_id	Creator tìm booking của mình
idx_bookings_class_id_status	Conflict check khi tạo booking
idx_bookings_status	Lọc theo trạng thái trên Homepage
idx_bookings_start_datetime	Lọc theo khoảng thời gian
idx_users_email, idx_users_username	Đăng nhập và kiểm tra unique
idx_refresh_tokens_token_hash	Tìm nhanh Refresh Token
idx_audit_logs_actor_created	Tra cứu audit theo actor và thời gian

7. BẢNG MÃ LỖI TỔNG HỢP

7.1 Mã lỗi HTTP (API Error Codes)

Tất cả response lỗi đều theo chuẩn JSON: `{ error_code, message, details?, timestamp }`

HTTP	Error Code	Tên ngắn	Mô tả & Khi xảy ra
201	SUCCESS_CREATED	Tạo mới thành công	Resource được tạo thành công
400	ERR_VALIDATION	Validation thất bại	Thiếu field bắt buộc, sai kiểu dữ liệu, vi phạm ràng buộc
400	ERR_INVALID_JSON	JSON không hợp lệ	Request body không parse được
401	ERR_TOKEN_MISSING	Thiếu token	Không có Authorization header
401	ERR_TOKEN_INVALID	Token không hợp lệ	JWT bị giả mạo hoặc sai chữ ký
401	ERR_TOKEN_EXPIRED	Token hết hạn	Access Token đã hết TTL 15 phút
401	ERR_INVALID_CREDENTIALS	Sai thông tin đăng nhập	Sai username/password (không tiết lộ cụ thể)
403	ERR_FORBIDDEN	Không có quyền	Role không đủ quyền thực hiện thao tác
403	ERR_ACCOUNT_INACTIVE	Tài khoản chưa kích hoạt	Tài khoản vẫn ở INACTIVE
403	ERR_NOT_OWNER	Không phải chủ sở hữu	Creator cố sửa booking của người khác
404	ERR_NOT_FOUND	Không tìm thấy	Resource không tồn tại hoặc đã xóa
404	ERR_USER_NOT_FOUND	User không tồn tại	Tìm user theo ID không có kết quả
404	ERR_CLASS_NOT_FOUND	Phòng học không tồn tại	class_id không hợp lệ hoặc đã xóa
404	ERR_BOOKING_NOT_FOUND	Booking không tồn tại	booking_id không hợp lệ hoặc đã xóa
409	ERR_EMAIL_EXISTS	Email đã tồn tại	Đăng ký với email đã có trong DB
409	ERR_USERNAME_EXISTS	Username đã tồn tại	Đăng ký với username đã dùng
409	ERR_CLASS_CONFLICT	Phòng bị đặt trùng	Khoảng thời gian yêu cầu đã có booking APPROVED/PENDING
409	ERR_WRONG_STATUSES	Trạng thái không phù hợp	Thao tác không hợp lệ với trạng thái hiện tại của booking

409	ERR_ALREADY_CLAIMED	Booking đã được nhận xử lý	Reviewer khác đã claim booking này
413	ERR_FILE_TOO_LARGE	File quá lớn	File vượt quá giới hạn kích thước (mặc định 10MB)
415	ERR_FILE_TYPE_INVALID	Sai định dạng file	Loại file không được phép upload
422	ERR_TIME_TOO_SOON	Thời gian quá gần	Đặt lớp trong vòng N giờ tới (vi phạm cấu hình)
422	ERR_TIME_TOO_FAR	Thời gian quá xa	Đặt lớp quá N ngày trong tương lai
422	ERR_ATTENDEES_EXCEEDED	Vượt sức chứa phòng	attendees_count > class.capacity
422	ERR_QUOTA_EXCEEDED	Vượt hạn mức booking	Creator vượt giới hạn booking/tuần
422	ERR_COMMENT_REQUIRED	Thiếu nhận xét	Reviewer/Approver chưa nhập nhận xét khi xử lý
422	ERR_CANNOT_DELETE_LAST_ADMIN	Không thể xóa Admin cuối	Hệ thống phải có ít nhất 1 Admin
423	ERR_ACCOUNT_LOCKED	Tài khoản bị khóa	Sai MK quá 5 lần liên tiếp (kèm unlock_at)
429	ERR_RATE_LIMIT	Quá nhiều request	Vượt rate limit của endpoint (kèm retry_after)
500	ERR_INTERNAL	Lỗi máy chủ	Lỗi không xác định phía server
503	ERR_SERVICE_UNAVAILABLE	Dịch vụ không khả dụng	DB down, email service lỗi...

7.2 Bảng Mã Lỗi Logic Nghiệp Vụ

Các lỗi logic được ghi vào `audit_log` và có thể trigger alert cho Admin.

Mã lỗi Logic	Mức độ	Mô tả & Xử lý
LOGIC-AUTH-001	 WARN	Cùng IP thử nhiều tài khoản khác nhau → Block IP-level 30 phút
LOGIC-AUTH-002	 HIGH	Refresh Token bị dùng lần 2 (replay attack) → Revoke toàn bộ session user, alert Admin
LOGIC-AUTH-003	 INFO	Token hết hạn → Client tự gọi /refresh; nếu fail → force logout về /login
LOGIC-AUTH-004	 WARN	Admin lock user đang online → Token vẫn valid 15 phút, sau đó không refresh được
LOGIC-REG-001	 INFO	Email xác nhận hết hạn (>24h) → User gửi lại, token cũ bị vô hiệu hóa ngay
LOGIC-REG-002	 WARN	Đăng ký lại email của tài khoản đã soft-delete → Thông báo 'Email đã tồn tại' (không tiết lộ)
LOGIC-BOOK-001	 HIGH	Conflict booking APPROVED trùng giờ trong DB → Alert Admin ngay, cần xử lý thủ công
LOGIC-BOOK-002	 WARN	Creator tạo 2 booking cùng phòng giờ < 30 giây → Cảnh báo duplicate, yêu cầu xác nhận
LOGIC-BOOK-003	 INFO	Phòng chuyển MAINTENANCE khi Creator đang mở form → Cảnh báo khi Creator lưu DRAFT
LOGIC-BOOK-004	 INFO	Creator submit DRAFT cũ hơn 7 ngày → Cảnh báo 'Thông tin có thể cũ, vui lòng xem lại'
LOGIC-REV-001	 INFO	Reviewer claim booking không thuộc phạm vi → 403 + ghi audit_log
LOGIC-REV-002	 WARN	Reviewer claim rồi bỏ quên >48h → Auto-unclaim, gửi thông báo Admin, booking về PENDING_REVIEW
LOGIC-REV-003	 INFO	Creator hủy booking khi Reviewer đang IN_REVIEW → Thông báo Reviewer, chuyển CANCELLED
LOGIC-APP-001	 HIGH	Race condition 2 Approver phê duyệt cùng lúc → Chỉ 1 thành công (DB lock), người sau 409
LOGIC-APP-002	 HIGH	2 booking APPROVED trùng phòng giờ → Alert Admin ngay, highlight trên dashboard
LOGIC-APP-003	 INFO	Email service lỗi khi Approve → Booking vẫn APPROVED, email vào retry queue (retry 3 lần)
LOGIC-ADM-001	 WARN	Admin xóa user có booking PENDING/IN_REVIEW → Cảnh báo, yêu cầu xử lý booking trước
LOGIC-ADM-002	 WARN	Admin giảm sức chứa phòng < attendees của booking APPROVED → Alert, không tự cancel
LOGIC-ADM-003	 INFO	Admin đổi role REVIEWER → CREATOR khi đang IN_REVIEW → Cảnh báo, yêu cầu reassign booking

8. THÔNG BÁO LỖI GIAO DIỆN (UI Error Messages)

Tất cả thông báo lỗi trên giao diện cần: rõ ràng, thân thiện, hướng dẫn hành động tiếp theo. Không được hiển thị technical error cho người dùng cuối.

8.1 Lỗi Validation Inline (hiện ngay dưới field)

Màn hình	Trường / Tình huống	Thông báo hiển thị (tiếng Việt)
Đăng ký	Họ tên — < 2 ký tự	"Họ tên phải có ít nhất 2 ký tự"
Đăng ký	Email — sai định dạng	"Địa chỉ email không đúng định dạng (vd: ten@company.com)"
Đăng ký	Username — có dấu/ký tự đặc biệt	"Tên đăng nhập chỉ gồm chữ cái, số và dấu gạch dưới"
Đăng ký	Mật khẩu — thiếu chữ hoa	"Mật khẩu phải có ít nhất 1 chữ hoa, 1 chữ thường và 1 chữ số"
Đăng ký	Xác nhận MK — không khớp	"Mật khẩu xác nhận chưa khớp với mật khẩu đã nhập"
Tạo booking	Tiêu đề — bỏ trống	"Vui lòng nhập tiêu đề cho yêu cầu đặt lớp"
Tạo booking	Phòng học — chưa chọn	"Vui lòng chọn phòng học cần đặt"
Tạo booking	Giờ bắt đầu — quá gần (< 2h)	"Thời gian bắt đầu phải cách hiện tại ít nhất 2 giờ"
Tạo booking	Số người > sức chứa phòng	"Phòng này chứa tối đa N người. Vui lòng điều chỉnh."
Tạo booking	File upload > 10MB	"File '[tên file]' vượt giới hạn 10MB. Vui lòng chọn file khác."
Tạo booking	Sai định dạng file	"Định dạng '[ext]' không được hỗ trợ. Chỉ chấp nhận: PDF, DOCX, PNG, JPG"
Từ chối	Lý do từ chối — bỏ trống	"Vui lòng nhập lý do từ chối để Creator hiểu và cải thiện"

8.2 Toast / Banner thông báo toàn trang

Loại	Màu	Nội dung & Tình huống
✓ Thành công	Xanh lá	"Đăng ký thành công! Vui lòng kiểm tra email để kích hoạt tài khoản."
✓ Thành công	Xanh lá	"Đã lưu nháp thành công lúc HH:mm"
✓ Thành công	Xanh lá	"Booking đã được gửi đi, chờ Reviewer xem xét!"

✓ Thành công	Xanh lá	"Đã phê duyệt thành công. Email xác nhận đã gửi cho người đặt."
⚠ Cảnh báo	Vàng	"Phòng học này đã có [N] booking trong ngày bạn chọn. Vui lòng kiểm tra lịch."
⚠ Cảnh báo	Vàng	"Phiên làm việc sắp hết hạn. Nhấn [Gia hạn] để tiếp tục."
⚠ Cảnh báo	Vàng	"Bạn còn 2 lần thử đăng nhập trước khi tài khoản bị khóa tạm thời."
✗ Lỗi	Đỏ	"Phòng học đã được đặt trong khoảng thời gian này. Vui lòng chọn thời gian khác."
✗ Lỗi	Đỏ	"Email hoặc mật khẩu không đúng. Vui lòng thử lại."
✗ Lỗi	Đỏ	"Tài khoản của bạn đã bị khóa đến [HH:mm DD/MM/YYYY]. Liên hệ Admin để được hỗ trợ."
✗ Lỗi	Đỏ	"Đã xảy ra lỗi, vui lòng thử lại. Nếu lỗi tiếp tục, hãy liên hệ bộ phận hỗ trợ."
i Thông tin	Xanh dương	"Phiên đăng nhập của bạn đã hết hạn. Vui lòng đăng nhập lại."
i Thông tin	Xanh dương	"Booking của bạn đã được Reviewer xem xét và chuyển lên Approver."

8.3 Dialog xác nhận (Confirmation Dialog)

Hành động	Nội dung Dialog
Submit booking	Tiêu đề: 'Xác nhận gửi yêu cầu' Nội dung: 'Sau khi gửi, bạn sẽ không thể chỉnh sửa yêu cầu này nữa. Bạn có chắc muốn tiếp tục?' Nút: [Gửi ngay] [Hủy]
Hủy booking	Tiêu đề: 'Hủy yêu cầu đặt lớp' Nội dung: 'Thao tác này không thể hoàn tác. Bạn có chắc muốn hủy yêu cầu này?' Nút: [Xác nhận hủy] (đỏ) [Giữ lại]
Từ chối booking	Tiêu đề: 'Từ chối yêu cầu' TextField: 'Lý do từ chối *' (bắt buộc, min 10 ký tự) Nút: [Xác nhận từ chối] [Hủy]
Phê duyệt booking	Tiêu đề: 'Phê duyệt yêu cầu' Nội dung: 'Phòng [Tên phòng] sẽ được đặt từ HH:mm đến HH:mm ngày DD/MM/YYYY' Nút: [Phê duyệt] (xanh lá) [Hủy]
Xóa người dùng	Tiêu đề: 'Xóa tài khoản' Nội dung: 'Tài khoản [tên user] sẽ bị vô hiệu hóa. Dữ liệu lịch sử vẫn được giữ lại.' Nút: [Xóa] (đỏ) [Hủy]
Đăng xuất tất cả	Tiêu đề: 'Đăng xuất tất cả thiết bị' Nội dung: 'Bạn sẽ bị đăng xuất khỏi tất cả thiết bị đang đăng nhập.' Nút: [Xác nhận] [Hủy]

8.4 Màn hình lỗi toàn trang (Full-page Error)

HTTP Code	Tiêu đề trang	Nội dung & Hành động gợi ý
-----------	---------------	----------------------------

401	 Chưa đăng nhập	'Bạn cần đăng nhập để truy cập trang này.' — Nút [Đăng nhập ngay]
403	 Không có quyền	'Bạn không có quyền truy cập trang này. Liên hệ Admin nếu cần hỗ trợ.' — Nút [Về trang chủ]
404	 Không tìm thấy	'Trang bạn tìm không tồn tại hoặc đã bị xóa.' — Nút [Về trang chủ]
500	 Lỗi hệ thống	'Đã xảy ra lỗi hệ thống. Chúng tôi đang khắc phục. Vui lòng thử lại sau.' — Nút [Thử lại]
503	 Bảo trì	'Hệ thống đang bảo trì và sẽ sớm hoạt động trở lại.' — Hiển thị thời gian dự kiến nếu biết

9. YÊU CẦU PHI CHỨC NĂNG

9.1 Hiệu năng (Performance)

Chỉ số	Yêu cầu
API Response Time (P95)	< 500ms trong điều kiện tải bình thường
API Response Time (P99)	< 1500ms dưới tải cao
Concurrent Users	Hỗ trợ tối thiểu 200 người dùng đồng thời
Trang chủ Load Time	First Contentful Paint < 2 giây
Conflict Check	< 100ms (sử dụng DB index tối ưu)
Export Excel	< 5 giây cho tập dữ liệu ≤ 10.000 bản ghi
DB Connection Pool	Min 5 / Max 50 connections (pg-pool)

9.2 Bảo mật (Security)

Hạng mục	Yêu cầu
Mật khẩu	bcrypt hash, salt rounds = 12. Không lưu plaintext.
JWT	Ký bằng RS256 (asymmetric). Access Token TTL = 15 phút.
HTTPS	Bắt buộc HTTPS cho toàn bộ API (redirect HTTP → HTTPS)
CORS	Chỉ cho phép origin được whitelist trong cấu hình
Rate Limiting	100 req/phút/IP cho public endpoints; 20 req/phút cho /auth/*
SQL Injection	Bắt buộc dùng Parameterized Queries hoặc ORM (TypeORM / Prisma)
XSS Prevention	Sanitize toàn bộ input text. Content-Security-Policy header.
Security Headers	Helmet.js: X-Frame-Options, X-Content-Type-Options, HSTS, v.v.
File Upload	Kiểm tra MIME type thực (magic bytes), không chỉ extension. Lưu Object Storage.
Audit Trail	Ghi log mọi thao tác nhạy cảm vào audit_logs với IP + timestamp

9.3 Khả dụng & Khôi phục (Availability & Recovery)

- Uptime mục tiêu: 99.5% (không kể bảo trì định kỳ)
- Health check endpoint: GET /api/v1/health → trả { status, db, timestamp }
- Graceful shutdown: hoàn thành request đang xử lý trước khi tắt server
- Database backup: tự động hàng ngày, lưu trữ tối thiểu 30 ngày
- Retry logic cho email service: tối đa 3 lần, exponential backoff

9.4 Khả năng mở rộng (Scalability)

- Stateless API (JWT-based) → dễ horizontal scaling (thêm instance)
- Tách biệt Business Logic Layer / Data Access Layer / Presentation Layer
- Cấu hình qua environment variables (12-factor app)
- Database migration quản lý qua Flyway hoặc Liquibase

9.5 Logging & Monitoring

Hạng mục	Yêu cầu
Log format	Structured JSON (Winston / Pino): timestamp, level, message, context, request_id
Log levels	DEBUG (dev only) INFO WARN ERROR FATAL
Request logging	Ghi: method, URL, status, response_time, user_id, IP cho mọi request
Error logging	Stack trace đầy đủ vào log, KHÔNG trả về client
Health check	GET /api/v1/health: { status:'ok' 'degraded', db:'connected', uptime, timestamp }
Alerting	Alert ngay khi: ERROR rate > 5%/phút, DB connection fail, disk > 85%

10. QUÊN MẬT KHẨU & ĐỔI MẬT KHẨU

10.1 Luồng Quên Mật Khẩu (Forgot Password)

12.1.1 Sơ đồ luồng



10.1.2 Màn hình /forgot-password

Bố cục & thành phần UI:

- Header: Logo + tiêu đề 'Khôi phục mật khẩu'
- Mô tả ngắn: 'Nhập địa chỉ email đã đăng ký. Chúng tôi sẽ gửi link đặt lại mật khẩu.'
- Field [Email *] — placeholder: 'Nhập email đã đăng ký' — autofocus
- Button [Gửi link khôi phục] — primary, loading spinner khi đang gửi
- Link [← Quay lại đăng nhập] → /login

Validation client-side:

- Email bỏ trống → 'Vui lòng nhập địa chỉ email'
- Email sai định dạng → 'Địa chỉ email không đúng định dạng'

10.1.3 Xử lý server-side

59. Nhận POST /api/v1/auth/forgot-password { email }
60. Tìm user theo email — NẾU KHÔNG TỒN TẠI: vẫn trả 200 (không tiết lộ email có tồn tại không)
61. Nếu user tồn tại và ACTIVE:
 - Tạo reset_token = crypto.randomBytes(32).toString('hex')
 - Hash token: SHA-256(reset_token) lưu vào bảng password_reset_tokens
 - TTL: 1 giờ kể từ thời điểm tạo
 - Vô hiệu hóa tất cả token reset cũ của user này
 - Gửi email với link: /reset-password?token=<raw_token>
62. Rate limit: tối đa 3 lần/giờ/email
63. Ghi audit_log: action='PASSWORD_RESET_REQUESTED', actor=email, ip=IP
64. Response 200: { message: 'Nếu email tồn tại trong hệ thống, link khôi phục đã được gửi.' }

10.1.4 Màn hình thành công — sau khi gửi email

- Icon ✉️ lớn + tiêu đề 'Kiểm tra hộp thư của bạn'
- Nội dung: 'Link khôi phục mật khẩu đã được gửi đến <email>. Link có hiệu lực trong 1 giờ.'
- Nút [Gửi lại] — disabled 60 giây, hiển thị countdown: 'Gửi lại sau Xs'
- Link [Không nhận được email? Kiểm tra thư mục Spam]
- Link [← Quay lại đăng nhập]

10.1.5 Màn hình đặt lại mật khẩu — /reset-password?token=<token>

Server validate token trước khi render form:

65. Nhận GET /reset-password?token=<raw_token>
66. Hash token → tìm trong bảng password_reset_tokens
67. Kiểm tra: chưa hết hạn (expires_at > NOW()), chưa dùng (used=false)
68. Nếu hợp lệ → render form đặt lại mật khẩu
69. Nếu không hợp lệ/hết hạn → redirect /reset-password/expired

Bố cục form /reset-password:

- Tiêu đề: 'Đặt mật khẩu mới'
- Field [Mật khẩu mới *] — icon toggle show/hide — thanh strength indicator
- Field [Xác nhận mật khẩu mới *] — hiển thị ✓/✗ so sánh realtime
- Danh sách yêu cầu mật khẩu dạng checklist động:
 - ✓/✗ Ít nhất 8 ký tự
 - ✓/✗ Có chữ hoa (A-Z)
 - ✓/✗ Có chữ thường (a-z)
 - ✓/✗ Có chữ số (0-9)
- Button [Đặt mật khẩu mới] — disabled cho đến khi tất cả điều kiện thỏa

10.1.6 Xử lý server khi đặt lại mật khẩu

70. Nhận POST /api/v1/auth/reset-password { token, new_password, confirm_password }
71. Hash token → kiểm tra hợp lệ trong DB (chưa hết hạn, chưa dùng)
72. Validate: new_password khớp confirm_password, đủ độ mạnh
73. Kiểm tra mật khẩu mới KHÔNG ĐƯỢC TRÙNG với mật khẩu hiện tại
74. UPDATE users SET password_hash = bcrypt(new_password, 12)
75. UPDATE password_reset_tokens SET used=true, used_at=NOW()
76. Revoke TẤT CẢ refresh_tokens của user này → buộc đăng nhập lại trên mọi thiết bị
77. Gửi email thông báo: 'Mật khẩu của bạn đã được thay đổi. Nếu không phải bạn, hãy liên hệ Admin ngay.'
78. Ghi audit_log: action='PASSWORD_RESET_COMPLETED'
79. Response 200 → Client redirect /login?message=password_reset_success

10.1.7 Màn hình /reset-password/expired

- Icon 🕒 + tiêu đề 'Link đã hết hạn'
- Nội dung: 'Link đặt lại mật khẩu đã hết hạn hoặc đã được sử dụng.'
- Nút [Gửi lại link mới] → redirect /forgot-password
- Link [Về trang đăng nhập]

⚠ Mã lỗi API — Quên Mật Khẩu

- | | |
|-------------------------------|---|
| • 200 SUCCESS | Luôn trả 200 dù email tồn tại hay không (bảo mật) |
| • 400 ERR_VALIDATION | Email sai định dạng hoặc bỏ trống |
| • 400 ERR_PASSWORD_MISMATCH | Mật khẩu mới và xác nhận không khớp |
| • 400 ERR_TOKEN_INVALID | Token không hợp lệ (sai, hết hạn, hoặc đã dùng) |
| • 400 ERR_TOKEN_EXPIRED | Token đã hết hạn (>1 giờ) |

- 422 | ERR_PASSWORD_WEAK | Mật khẩu mới không đủ độ mạnh
- 422 | ERR_PASSWORD_SAME_AS_OLD | Mật khẩu mới trùng với mật khẩu cũ
- 429 | ERR_RATE_LIMIT | Quá 3 yêu cầu reset/giờ từ cùng email hoặc IP
- 503 | ERR_EMAIL_SERVICE_DOWN | Không gửi được email



Mã lỗi Logic — Quên Mật Khẩu

- LOGIC-FP-001 | Cùng email nhận >3 request/giờ → Rate limit, ghi cảnh báo vào audit_log
- LOGIC-FP-002 | Token dùng lần 2 (replay) → Vô hiệu token, gửi email cảnh báo cho user
- LOGIC-FP-003 | User bị INACTIVE/LOCKED đặt lại MK thành công → Vẫn không đăng nhập được đến khi Admin kích hoạt
- LOGIC-FP-004 | Admin reset password hộ user → Cần flow riêng qua Admin panel, không qua forgot-password

10.2 Luồng Đổi Mật Khẩu (Change Password)

10.2.1 Sơ đồ luồng



10.2.2 Màn hình đổi mật khẩu — /profile/change-password

Bố cục & thành phần UI:

- Breadcrumb: Trang chủ > Hồ sơ cá nhân > Đổi mật khẩu
- Card form giữa trang, width max 480px
- Field [Mật khẩu hiện tại *] — icon toggle show/hide
- Field [Mật khẩu mới *] — icon toggle show/hide — strength indicator
- Field [Xác nhận mật khẩu mới *] — kiểm tra khớp realtime

Checklist yêu cầu mật khẩu mới (cập nhật động khi gõ):

Trạng thái	Điều kiện	Hiển thị UI
✓ / ✗	Ít nhất 8 ký tự	Màu xanh khi đạt, màu đỏ khi chưa đạt
✓ / ✗	Có ít nhất 1 chữ hoa (A-Z)	Cập nhật realtime khi người dùng gõ
✓ / ✗	Có ít nhất 1 chữ thường (a-z)	Không cần focus ra ngoài field
✓ / ✗	Có ít nhất 1 chữ số (0-9)	Thanh progress: 0-1 tiêu chí=Yếu, 2-3=TB, 4=Mạnh
✓ / ✗	Mật khẩu mới ≠ mật khẩu cũ	Chỉ kiểm tra sau khi blur khỏi field

- Button [Cập nhật mật khẩu] — primary, disabled khi form chưa hợp lệ
- Button [Hủy] — về trang hồ sơ cá nhân
- Cảnh báo nhỏ bên dưới button: 'Sau khi đổi mật khẩu, bạn sẽ được yêu cầu đăng nhập lại trên tất cả thiết bị.'

10.2.3 Xử lý server-side

- Nhận PUT /api/v1/auth/change-password { current_password, new_password, confirm_password } + Bearer Token
- Xác thực JWT → lấy user_id
- Lấy user từ DB, bcrypt.compare(current_password, password_hash)
- Nếu mật khẩu hiện tại SAI → trả ERR_WRONG_CURRENT_PASSWORD
- Validate new_password: đủ độ mạnh, khớp confirm_password, không trùng mật khẩu cũ
- UPDATE users SET password_hash = bcrypt(new_password, 12), updated_at=NOW()
- Revoke TẤT CẢ refresh_tokens của user (kể cả token hiện tại đang dùng)
- Gửi email thông báo: 'Mật khẩu tài khoản của bạn vừa được thay đổi lúc HH:mm DD/MM/YYYY. Nếu không phải bạn, hãy liên hệ Admin ngay.'
- Ghi audit_log: action='PASSWORD_CHANGED', actor=user_id
- Response 200 → Client xóa tokens local → redirect /login?message=password_changed

10.2.4 Trường hợp đặc biệt: `must_change_password = true`

Khi Admin tạo tài khoản mới, flag `must_change_password=true` được set. Flow bắt buộc đổi mật khẩu lần đầu:

90. User đăng nhập thành công → Server kiểm tra `must_change_password`
91. Nếu true → Access Token có claim { `force_password_change: true` }
92. Client nhận claim → bắt buộc redirect `/profile/change-password`
93. Tất cả API khác trả 403 `ERR_MUST_CHANGE_PASSWORD` đến khi đổi xong
94. Sau khi đổi thành công → `UPDATE must_change_password=false` → User vào hệ thống bình thường

Mã lỗi API — Đổi Mật Khẩu

- 200 | `SUCCESS` | Đổi mật khẩu thành công, sessions bị revoke
- 400 | `ERR_VALIDATION` | Thiếu trường hoặc sai định dạng
- 400 | `ERR_PASSWORD_MISMATCH` | Mật khẩu mới và xác nhận không khớp
- 401 | `ERR_UNAUTHORIZED` | Token không hợp lệ hoặc hết hạn
- 403 | `ERR_WRONG_CURRENT_PASSWORD` | Mật khẩu hiện tại không đúng
- 403 | `ERR_MUST_CHANGE_PASSWORD` | Bắt buộc đổi MK trước khi dùng hệ thống (Admin tạo mới)
- 422 | `ERR_PASSWORD_WEAK` | Mật khẩu mới không đủ độ mạnh
- 422 | `ERR_PASSWORD_SAME_AS_OLD` | Mật khẩu mới trùng với mật khẩu hiện tại

Mã lỗi Logic — Đổi Mật Khẩu

- `LOGIC-CP-001` | User đổi MK thành công nhưng email service lỗi → MK vẫn đổi, email vào retry queue
- `LOGIC-CP-002` | User đổi MK khi đang có booking đang xử lý → Booking không bị ảnh hưởng
- `LOGIC-CP-003` | Nhiều tab cùng mở → Tab khác nhận 401 sau khi đổi MK, hiển thị banner 'Phiên làm việc hết hạn'

11. VALIDATE UI CHI TIẾT — ĐĂNG NHẬP & ĐĂNG KÝ

Mục này mô tả toàn bộ hành vi validate trực quan trên giao diện: khi nào hiện lỗi, ẩn lỗi, trạng thái field, màu sắc và thông điệp cụ thể.

11.1 Validate UI — Màn hình Đăng Ký (/register)

11.1.1 Nguyên tắc validate chung

- Validate KHÔNG chạy ngay khi trang load — chỉ bắt đầu sau lần đầu người dùng tương tác
- Validate realtime: chạy khi người dùng ĐANG GÕ (onChange) sau lần đầu blur
- Validate blur: luôn chạy khi người dùng rời khỏi field (onBlur)
- Màu field hợp lệ: viền xanh lá #70AD47 + icon ✓
- Màu field lỗi: viền đỏ #C00000 + icon ✗ + thông báo lỗi màu đỏ bên dưới
- Màu field mặc định: viền xám #CCCCCC
- Button [Đăng ký] disabled cho đến khi TẤT CẢ trường bắt buộc hợp lệ VÀ checkbox ToS đã tick

11.1.2 Chi tiết validate từng trường

Trường	Khi nào check	Điều kiện	Thông báo lỗi UI
Họ và tên	onBlur + onChange	Bỏ trống	'Vui lòng nhập họ và tên'
	onBlur + onChange	< 2 ký tự	'Họ tên phải có ít nhất 2 ký tự'
	onBlur + onChange	> 100 ký tự	'Họ tên không được vượt quá 100 ký tự'
	onBlur	Có số/ký tự đặc biệt	'Họ tên chỉ được chứa chữ cái và khoảng trắng'
Email	onBlur + onChange	Bỏ trống	'Vui lòng nhập địa chỉ email'
	onBlur + onChange	Sai định dạng	'Địa chỉ email không hợp lệ (vd: ten@congtv.com)'
	onBlur (gọi API)	Email đã tồn tại	'Email này đã được sử dụng. Thử đăng nhập?' [Link /login]
Tên đăng nhập	onBlur + onChange	Bỏ trống	'Vui lòng nhập tên đăng nhập'

	onChange	< 6 ký tự	'Tên đăng nhập phải có ít nhất 6 ký tự' + counter: 'X/6'
	onChange	> 50 ký tự	'Tên đăng nhập tối đa 50 ký tự'
	onChange	Có ký tự không hợp lệ	'Chỉ dùng chữ cái không dấu, số và dấu _ (gạch dưới)'
	onBlur (gọi API)	Username đã tồn tại	'Tên đăng nhập đã có người dùng. Thử: ten_1, ten_2?'
Mật khẩu	onChange	< 8 ký tự	Strength bar: ĐỎ 'Mật khẩu quá yếu' + checklist điều kiện
	onChange	Có chữ hoa+thường+số	Strength bar: VÀNG 'Mật khẩu trung bình'
	onChange	Đủ 4 tiêu chí + ≥12 ký tự	Strength bar: XANH 'Mật khẩu mạnh'
	onBlur	Bỏ trống	'Vui lòng nhập mật khẩu'
Xác nhận MK	onChange	Đang gõ, chưa khớp	Hiện thị icon ✗ màu đỏ bên phải field, chưa hiện text lỗi
	onBlur	Không khớp MK	'Mật khẩu xác nhận chưa khớp với mật khẩu đã nhập'
	onChange	Khớp MK	Hiện thị icon ✓ màu xanh, text 'Mật khẩu khớp'
Số điện thoại	onBlur	Nhập nhưng < 10 số	'Số điện thoại phải gồm đúng 10 chữ số'
(tùy chọn)	onBlur	Không bắt đầu bằng 0	'Số điện thoại Việt Nam phải bắt đầu bằng số 0'
Điều khoản (ToS)	onSubmit	Chưa tick	'Bạn cần đồng ý với Điều khoản sử dụng để tiếp tục' — highlight checkbox màu đỏ

11.1.3 Trạng thái nút Đăng ký

Trạng thái	Điều kiện
☐ DISABLED (xám)	Một hoặc nhiều trường bắt buộc chưa hợp lệ, hoặc chưa tick ToS
☒ ENABLED (xanh)	Tất cả trường hợp lệ VÀ ToS đã tick
 LOADING (spinner)	Đang gọi API — disable click, hiển thị spinner trong button
☒ SUCCESS	API trả 201 — flash xanh 0.5s rồi redirect



ERROR (đỏ)

API trả lỗi — hiện banner đỏ phía trên form, scroll lên top

11.1.4 Kiểm tra trùng email/username (real-time API check)

- Gọi GET /api/v1/auth/check-email?email=<value> sau khi blur — debounce 500ms
- Gọi GET /api/v1/auth/check-username?username=<value> sau khi blur — debounce 500ms
- Hiện thị spinner nhỏ trong field khi đang gọi API kiểm tra
- Kết quả: available=true → ✓ xanh; available=false → ✗ đỏ + thông báo lỗi
- Nếu gọi API lỗi (network) → không hiện thị lỗi realtime, để server validate khi submit

11.2 Validate UI — Màn hình Đăng Nhập (/login)

11.2.1 Nguyên tắc validate đăng nhập

- Chỉ validate KHÔNG BỎ TRỐNG tại client — không kiểm tra định dạng để tránh tiết lộ thông tin
- Tất cả lỗi xác thực thực sự (sai MK, khóa tài khoản...) đến từ server sau khi submit
- KHÔNG hiện lỗi cụ thể về field nào sai (bảo mật) — chỉ hiện thông báo chung

11.2.2 Chi tiết validate từng trường

Trường	Khi nào check	Điều kiện	Hành vi UI
Username/Email	onBlur, onSubmit	Bỏ trống	'Vui lòng nhập tên đăng nhập hoặc email'
Mật khẩu	onBlur, onSubmit	Bỏ trống	'Vui lòng nhập mật khẩu'
Cả hai	onSubmit	Sai thông tin	Banner đỏ: 'Tên đăng nhập hoặc mật khẩu không đúng' — KHÔNG nói field nào sai

11.2.3 Các trạng thái banner lỗi sau submit

Tình huống	Thông báo UI hiển thị
Sai thông tin (lần 1-2)	● 'Tên đăng nhập hoặc mật khẩu không đúng.'
Sai lần 3	● 'Thông tin đăng nhập không đúng. Bạn còn 2 lần thử trước khi tài khoản bị khóa tạm thời.'
Sai lần 4	● 'Thông tin đăng nhập không đúng. Còn 1 lần thử. Dùng [Quên mật khẩu?] để khôi phục.'
Sai lần 5 (bị khóa)	● 'Tài khoản đã bị khóa tạm thời đến 14:30 ngày 04/05/2026. Liên hệ Admin hoặc dùng [Quên mật khẩu?].'
Tài khoản INACTIVE	● 'Tài khoản chưa được kích hoạt. Vui lòng kiểm tra email hoặc liên hệ Admin để được hỗ trợ.'
Email chưa xác nhận	● 'Email chưa được xác nhận. [Gửi lại email xác nhận] để tiếp tục.' (link action)

Đang bị khóa (load trang)	● Banner hiển thị ngay khi load: 'Tài khoản bị khóa đến HH:mm DD/MM. Countdown realtime đến khi mở khóa.'
Network error	● 'Không thể kết nối. Vui lòng kiểm tra internet và thử lại.' — Nút [Thử lại]
Server lỗi 500	● 'Hệ thống đang gặp sự cố. Vui lòng thử lại sau ít phút.'

11.2.4 Trạng thái nút Đăng nhập

Trạng thái	Mô tả
☐ DISABLED	Một trong hai trường bỏ trống
☒ ENABLED	Cả hai trường đã có giá trị
LOADING	Đang gọi API, disable button + spinner
● LOCKED (đặc biệt)	Hiển thị disabled + tooltip 'Tài khoản bị khóa đến HH:mm' khi tài khoản locked

11.2.5 Hành vi nâng cao

- Auto-fill: hỗ trợ trình duyệt autocomplete, không chặn password manager
- Capslock detection: hiển thị cảnh báo '⚠ CapsLock đang bật' khi nhập mật khẩu
- Paste support: cho phép paste mật khẩu (không disable paste)
- Enter key: nhấn Enter trong bất kỳ field nào → submit form
- Tab order: Username/Email → Mật khẩu → Remember me → Nút Đăng nhập
- Sau đăng nhập thành công: redirect về URL trước đó (nếu bị redirect về /login), hoặc /home

12. THÔNG BÁO REALTIME (Real-time Notifications)

Hệ thống thông báo realtime sử dụng Server-Sent Events (SSE) hoặc WebSocket để đẩy cập nhật tức thì đến client mà không cần polling. Người dùng nhận thông báo ngay khi trạng thái booking thay đổi.

12.1 Kiến Trúc Hệ Thống Thông Báo

12.1.1 Lựa chọn công nghệ

Công nghệ	Khi nào dùng	Ưu điểm / Nhược điểm
SSE (Server-Sent Events)	Phù hợp dự án này	✓ Đơn giản, HTTP thuần, auto-reconnect ✗ Chỉ server→client, max 6 kết nối/domain
WebSocket	Khi cần 2 chiều	✓ 2 chiều, latency thấp ✗ Phức tạp hơn, cần WS server riêng
Polling (fallback)	Thiết bị cũ/proxy block SSE	✓ Đơn giản, tương thích cao ✗ Tốn bandwidth, delay 5-30s

→ **Khuyến nghị:** Dùng SSE làm primary. Fallback về Long Polling nếu SSE không khả dụng.

12.1.2 Endpoint SSE

Thuộc tính	Giá trị
Endpoint	GET /api/v1/notifications/stream
Auth	Bearer Token trong header Authorization (SSE không hỗ trợ custom header từ browser → dùng token trong query: ?token=<jwt>)
Content-Type	text/event-stream; charset=utf-8
Headers	Cache-Control: no-cache Connection: keep-alive X-Accel-Buffering: no
Heartbeat	Server gửi comment ': ping' mỗi 30 giây để giữ kết nối
Reconnect	Client tự reconnect sau 3 giây nếu mất kết nối (EventSource built-in)

12.1.3 Cấu trúc Event SSE

Mỗi event có định dạng:

```
id: <event_id>\nretry: 3000\nevent: <event_type>\ndata:
{"type": "BOOKING_STATUS_CHANGED", "booking_id": "uuid", "old_status": "PENDING_REVIEW", "new_status": "IN_REVIEW", "message": "Reviewer đang xem xét yêu cầu của bạn", "timestamp": "2026-05-04T10:00:00Z"}
```

12.2 Danh Sách Các Loại Sự Kiện Realtime

Event Type	Gửi đến	Khi nào trigger	Nội dung thông báo
------------	---------	-----------------	--------------------

BOOKING_SUBMITTED	REVIEWER	Creator submit	'Có yêu cầu đặt lớp mới cần xem xét'
BOOKING_CLAIMED	CREATOR	Reviewer claim	'Reviewer đang xem xét yêu cầu của bạn'
BOOKING_FORWARDED	APPROVE RCREATOR	Reviewer forward	Approver: 'Có yêu cầu chờ phê duyệt' Creator: 'Đang chờ phê duyệt cuối'
BOOKING_APPROVED	CREATOR REVIEWER	Approver approve	🎉 Yêu cầu đặt lớp [Tên phòng] ngày DD/MM đã được phê duyệt!
BOOKING_REJECTED	CREATOR	Reviewer/Approver reject	❌ Yêu cầu đặt lớp bị từ chối. Xem lý do →'
BOOKING_CANCELLED	REVIEWER APPROVER	Creator cancel	'⚠️ Yêu cầu [tiêu đề] đã bị Creator hủy'
BOOKING_COMMENT_ADDED	Liên quan	Thêm nhận xét	'Có nhận xét mới từ [Reviewer/Approver] trên booking của bạn'
CLASS_CONFLICT_ALERT	ADMIN	Phát hiện trùng lịch	'⚠️ CẢNH BÁO: Phòng [X] bị đặt trùng lịch. Cần xử lý ngay!'
USER_ACCOUNT_ACTIVATED	USER	Admin kích hoạt	'✅ Tài khoản của bạn đã được kích hoạt. Đăng nhập ngay!'
USER_ROLE_CHANGED	USER	Admin đổi role	'👤 Vai trò tài khoản của bạn đã được cập nhật thành [Role mới]'
SYSTEM_MAINTENANCE	ALL	Admin thông báo	'🔧 Hệ thống sẽ bảo trì lúc HH:mm. Vui lòng lưu công việc.'
SESSION_EXPIRED	USER	Token revoked	'Phiên đăng nhập đã hết hạn. Vui lòng đăng nhập lại.'

12.3 Giao Diện Thông Báo (Notification UI)

12.3.1 Icon thông báo trên Navigation Bar

- Icon 🛎️ góc trên phải — badge đỏ hiển thị số thông báo chưa đọc
- Badge tối đa hiển thị '99+' nếu > 99 thông báo chưa đọc
- Icon nhấp nháy / pulse animation khi có thông báo mới realtime
- Click icon → mở Notification Panel dạng dropdown

12.3.2 Notification Panel (dropdown)

- Tiêu đề: 'Thông báo' + nút [Đánh dấu tất cả đã đọc] + nút [Xem tất cả]
- Danh sách tối đa 10 thông báo gần nhất trong dropdown
- Mỗi dòng thông báo: Icon loại | Nội dung | Thời gian (relative: '2 phút trước') | Chấm xanh nếu chưa đọc
- Click vào thông báo → đánh dấu đã đọc + navigate đến trang liên quan (chi tiết booking)
- Hover vào dòng → hiện nút ✕ xóa thông báo đó

- Loading skeleton khi đang tải danh sách

12.3.3 Toast Notification (popup góc màn hình)

- Xuất hiện góc dưới phải màn hình khi nhận event realtime
- Auto-dismiss sau 5 giây — có progress bar countdown màu xanh
- Nút [X] để đóng thủ công
- Stack tối đa 3 toast cùng lúc — toast cũ tự dismiss khi có toast mới thứ 4

Loại Toast	Màu	Hành vi
APPROVED 🎉	Xanh lá	Tự dismiss sau 8 giây (quan trọng hơn) + âm thanh thông báo nhẹ
REJECTED ❌	Đỏ	Tự dismiss sau 8 giây, nút [Xem lý do] navigate đến chi tiết
INFO i	Xanh dương	Tự dismiss sau 5 giây
WARNING ⚠️	Cam	Không auto-dismiss — phải đóng thủ công
SESSION_EXPIRE D 🚫	Đỏ đậm	Không auto-dismiss — nút [Đăng nhập lại] bắt buộc

12.3.4 Trang thông báo đầy đủ — /notifications

- Hiện thị TẤT CẢ thông báo với phân trang
- Bộ lọc: Tất cả | Chưa đọc | Booking | Hệ thống
- Mỗi dòng: Icon | Nội dung đầy đủ | Thời gian tuyệt đối (DD/MM/YYYY HH:mm) | Trạng thái đọc
- Nút [Đánh dấu tất cả đã đọc] — batch update
- Nút [Xóa tất cả đã đọc]
- Click mỗi thông báo → navigate đến context liên quan

12.4 Xử Lý Kết Nối & Trạng Thái

12.4.1 Lifecycle kết nối SSE

- Client kết nối: `new EventSource('/api/v1/notifications/stream?token=<jwt>')`
- Server xác thực token, đăng ký channel cho `user_id`
- Kết nối thành công: hiển thị indicator 🟢 Online (tùy chọn)
- Mất kết nối: `EventSource` tự retry sau 3 giây — hiển thị indicator 🔴 Offline
- Kết nối lại thành công: gọi `GET /api/v1/notifications?since=<last_event_id>` để lấy bù các event đã bỏ lỡ
- Token hết hạn trong khi đang kết nối → đóng SSE → client refresh token → reconnect

12.4.2 Xử lý khi offline / mất mạng

- Hiện thị banner vàng ở top: '⚠️ Mất kết nối. Thông báo realtime tạm dừng. Đang thử kết nối lại...'
- Auto retry: 3s → 5s → 10s → 30s (exponential backoff, max 30s)
- Kết nối lại: ẩn banner + hiện toast xanh 'Đã kết nối lại'
- Trong thời gian offline: badge thông báo vẫn cập nhật qua polling 30s làm fallback

12.4.3 Xử lý đa tab (Multiple Tabs)

- Mỗi tab tạo 1 SSE connection riêng
- Server fan-out event đến TẤT CẢ connection của user_id
- Đánh dấu đã đọc ở 1 tab → cập nhật realtime sang các tab khác (qua SSE event READ_STATUS_CHANGED)
- Đăng xuất ở 1 tab → gửi SESSION_EXPIRED event → tắt cả tab đều force logout

12.5 API Thông Báo

Method	Endpoint	Mô tả
GET	/api/v1/notifications/stream	SSE endpoint — stream thông báo realtime
GET	/api/v1/notifications	Danh sách thông báo (phân trang, lọc read/unread)
GET	/api/v1/notifications/unread-count	Số thông báo chưa đọc (cho badge icon)
PATCH	/api/v1/notifications/:id/read	Đánh dấu 1 thông báo đã đọc
PATCH	/api/v1/notifications/read-all	Đánh dấu tất cả đã đọc
DELETE	/api/v1/notifications/:id	Xóa 1 thông báo
DELETE	/api/v1/notifications/read	Xóa tất cả thông báo đã đọc

⚠ Mã lỗi API — Thông Báo Realtime

- 200 | SUCCESS | Kết nối SSE thành công hoặc thao tác thành công
- 401 | ERR_TOKEN_MISSING | Không có token trong query param
- 401 | ERR_TOKEN_INVALID | Token không hợp lệ hoặc đã hết hạn
- 404 | ERR_NOTIFICATION_NOT_FOUND | Notification ID không tồn tại hoặc không thuộc user
- 429 | ERR_TOO_MANY_CONNECTIONS | User đang có quá nhiều SSE connections (>10 tabs)
- 503 | ERR_SSE_UNAVAILABLE | SSE service tạm thời không khả dụng, dùng polling fallback

💡 Mã lỗi Logic — Thông Báo Realtime

- LOGIC-NOTIF-001 | Event gửi thất bại (user offline) → Lưu vào notifications table, gửi khi reconnect
- LOGIC-NOTIF-002 | User không online → Gửi email fallback cho event APPROVED/REJECTED
- LOGIC-NOTIF-003 | Fan-out event đến >100 user cùng lúc → Dùng message queue (Bull/Redis) để xử lý async
- LOGIC-NOTIF-004 | Token hết hạn khi đang stream → Client nhận event TOKEN_EXPIRED, tự động refresh + reconnect
- LOGIC-NOTIF-005 | DB bảng notifications quá lớn → Tự động xóa thông báo > 90 ngày qua cron job hàng đêm

12.6 Database — Bảng notifications

Cột	Kiểu dữ liệu	Ràng buộc	Mô tả
id	UUID	PK	Primary Key
user_id	UUID	FK → users	Người nhận thông báo
event_type	VARCHAR(60)	NOT NULL	BOOKING_APPROVED / BOOKING_REJECTED / v.v.
title	VARCHAR(200)	NOT NULL	Tiêu đề thông báo ngắn gọn
message	TEXT	NOT NULL	Nội dung đầy đủ của thông báo
metadata	JSONB	NULLABLE	{ booking_id, class_id, link } — dữ liệu kèm theo
is_read	BOOLEAN	DEFAULT false	Đã đọc chưa
read_at	TIMESTAMP Z	NULLABLE	Thời điểm đọc
created_at	TIMESTAMP Z	DEFAULT NOW()	Thời điểm tạo thông báo

Index: idx_notifications_user_id_is_read — tăng tốc truy vấn badge count và danh sách chưa đọc.